

Auditoria de Seguranca — Antes e Depois

Arsenal Open Source - Fabrica Universal

Data: 2026-08-28

Gate do ciclo: REPROVADO

O ciclo nao fecha enquanto os pontos abaixo existirem:

- 17 achado(s) novo(s) apos a correcao: Duplicata do stack do Fluxo 4 carrega os mesmos segredos literais (alta); Quickstart do Keycloak publica credencial de administrador admin/admin em bloco copiável (alta); Comando rápido do WAHA publica chave de API literal para a ponte de WhatsApp (alta); Comando rápido do Dolibarr publica senha de administrador do ERP como admin (alta); Comando rápido do Odoos fixa a senha do Postgres em valor conhecido (media); Mesma senha de Postgres literal no dossiê de Salesforce (media); Campo SMTP_PASSWORD escapa do padrão de placeholder que o próprio manual ensina a substituir (baixa); Compilador de compêndio interpola JSON cru em HTML e em href, sem nenhum escape (media); Compilador de dossiê vertical repete a interpolação sem escape em href e corpo (media); Compilador de ecossistema monta href com aspas simples, tornando a quebra de atributo trivial (media); Bibliografia de trilha injeta URL, título e autor de pesquisa web direto no HTML (media); Tabela de fontes verificadas do manual operacional interpola dados de terceiros sem escape (media); Sanitização parcial: vps_generator escapa a tabela e esquece o target-box (baixa); Renderizador desfaz o escape do Pandoc em blocos Mermaid e ainda liga securityLevel loose (baixa); linter.js executa eslint via shell com lista de arquivos concatenada sem quoting (baixa); Slug de CLI vira caminho de escrita sem allowlist, e componente absoluto descarta a base (baixa); Slug do Fluxo 1 entra em caminho sem remover separadores nem sequência de subida (baixa)

Resultado

8 ANTES	5 CORRIGIDOS	3 PERSISTENTES	17 NOVOS	20 DEPOIS
------------	-----------------	-------------------	-------------	--------------

Taxa de correcao: 50.0% (exclui informativas — divida arquitetural nao conta como vulnerabilidade)

Antes

Depois



- Alta — 2 (25.0%)
- Media — 3 (37.5%)
- Baixa — 1 (12.5%)
- Informativa — 2 (25.0%)



- Alta — 6 (30.0%)
- Media — 8 (40.0%)
- Baixa — 6 (30.0%)

Severidade lado a lado



Corrigidos (5)

Severidade	Arquivo	Descricao
Media	scripts/	Ausencia de validacao de startup para variaveis criticas
Media	scripts/gerar-index-organizacao.py	Interpolacao sem escape de dado de terceiro no gerador do portal
Baixa	scripts/git_sync.py	Mensagem de commit vinda de argv sem validacao
Informativa	scripts/aplicar_padrao_diamante_49.py	innerHTML com template string no JavaScript gerado
Informativa	scripts/estado_esteira.py	Ausencia de coluna de proprietario no esquema da esteira

Persistentes (3)

Severidade	Arquivo	Descricao
Media	.env	Credenciais operacionais vivas em .env de texto plano na estação de trabalho
Alta	output/05-auditorias-vps/ecossistemas/ecos-google-workspace/02-guias-de-engenharia-e-infraestrutura/01-stack-swarm-producao-integrada.yml	Stack Swarm de produção versionada com senha de banco e JWT do OnlyOffice literais, iguais para todo leitor
Alta	scripts/verificar_segredos.py	Gate de segredos só detecta valor entre aspas, deixando passar atribuição YAML e docker -e

Novos (17)

Severidade	Arquivo	Descricao
Alta	output/04-ecossistemas/ecos-google-workspace/02-guias-de-engenharia-e-infraestrutura/docker-stack-workspace.yml	Duplicata do stack do Fluxo 4 carrega os mesmos segredos literais
Alta	scripts/compilar_35_39.py	Quickstart do Keycloak publica credencial de administrador admin/admin em bloco copiável

Severidade	Arquivo	Descricao
Alta	scripts/data/dossie-vertical-twilio.json	Comando rápido do WAHA publica chave de API literal para a ponte de WhatsApp
Alta	scripts/data/dossie-operacao-industrial.json	Comando rápido do Dolibarr publica senha de administrador do ERP como admin
Media	scripts/data/dossie-vertical-revops.json	Comando rápido do Odoo fixa a senha do Postgres em valor conhecido
Media	scripts/data/dossie-vertical-salesforce.json	Mesma senha de Postgres literal no dossiê de Salesforce
Baixa	scripts/data/manual-mautic.json	Campo SMTP_PASSWORD escapa do padrão de placeholder que o próprio manual ensina a substituir
Media	scripts/compilar_compendio_diamante.py	Compilador de compêndio interpola JSON cru em HTML e em href, sem nenhum escape
Media	scripts/compilar_compendio_vertical.py	Compilador de dossiê vertical repete a interpolação sem escape em href e corpo
Media	scripts/compilar_ecossistema_tripartite.py	Compilador de ecossistema monta href com aspas simples, tornando a quebra de atributo trivial
Media	scripts/padrees/template_trilha_aprendizado.py	Bibliografia de trilha injeta URL, título e autor de pesquisa web direto no HTML
Media	scripts/padrees/template_manual_operacional.py	Tabela de fontes verificadas do manual operacional interpola dados de terceiros sem escape
Baixa	scripts/modulos/vps_generator.py	Sanitização parcial: vps_generator escapa a tabela e esquece o target-box
Baixa	scripts/renderizador_html_diamante.py	Renderizador desfaz o escape do Pandoc em blocos Mermaid e ainda liga securityLevel loose

Severidade	Arquivo	Descricao
Baixa	scripts/linter.js	linter.js executa eslint via shell com lista de arquivos concatenada sem quoting
Baixa	scripts/run_fluxo5.py	Slug de CLI vira caminho de escrita sem allowlist, e componente absoluto descarta a base
Baixa	scripts/compilar_lista_horizontal_tripartite.py	Slug do Fluxo 1 entra em caminho sem remover separadores nem sequência de subida

Achado novo tem duas origens possiveis: regressao introduzida pela correcao, ou achado que a primeira passada nao viu. Distinga os dois casos antes de fechar o ciclo.